Cyber AI Platform MVP Design

Vulnerability Chain Analysis with Approval-Gated Jira Epic and Ticket Creation

Updated service split: policy-api + registry-api | Python/FastAPI stack | Temporal workflow runtime

1. Executive Summary

This MVP focuses on a single high-value cyber use case: vulnerability chain analysis. The platform determines whether vulnerabilities across assets, applications, identities, network paths, and data stores can combine into real business or data exposure risk. The MVP also generates evidence-backed Jira epic/story/task drafts and supports approval-gated Jira creation.

- MVP scope: vulnerability_chaining_workflow only.
- Architecture style: governed workflow mode, not unrestricted dynamic agent execution.
- Workflow engine: Temporal is recommended for durable execution, retries, timeouts, cancellation, approvals, and quality loops.
- Service split: policy-api owns runtime authorization and constraints; registry-api owns approved capability definitions.
- Jira integration: draft generation is automatic; actual Jira creation requires approval.
- Technology direction: Python/FastAPI APIs and workers; no Spring Boot; model-gateway-service remains generic and unnamed.

2. MVP Scope

In Scope	Out of Scope
Vulnerability chain analysis	Full cross-domain dynamic planner
Evidence-backed cyber risk scoring	Automatic patching or remediation
Graph path and data impact analysis	Firewall, identity, or secret rotation actions
Jira epic/story/task draft generation	Auto-closing or auto-marking Jira remediated
Approval-gated Jira ticket creation	Full memory agent or autonomous skill learning
Tenant-scoped context, policy checks, audit trail	Full cyber domain agent marketplace

3. MVP Services and Tech Stack

#	Service	Purpose	Tech Stack
1	chat-api-service	Chat endpoint, streaming, workflow status, execution stream fanout	Python, FastAPI, SSE/WebSocket, Redis
2	context-api	Identity, tenant, session, conversation history, basic memory	Python, FastAPI, Postgres, Redis
3	orchestrator-service	Intent classification, workflow routing, execution mode selection	Python, FastAPI, Pydantic
4	policy-api	Runtime authorization, tenant boundary, masking, approval	Python, FastAPI, OPA/Cedar/custom policy

		policy, obligations	engine, Postgres
5	registry-api	Workflow, agent, skill, tool, model, prompt, data product definitions	Python, FastAPI, Postgres
6	workflow-runtime-service	Starts and monitors Temporal workflows; exposes execution status/cancel/signal APIs	Python, FastAPI, Temporal SDK
7	agent-runtime-service	Runs vulnerability chaining agent and skills	Python, FastAPI, async workers, Pydantic
8	tool-gateway-service	Tool authorization, schema validation, graph guard, SQL guard, masking, Jira adapter enforcement	Python, FastAPI, Redis
9	cyber-domain-api	Cyber data products, graph paths, risk scoring, evidence store	Python, FastAPI, Graph DB, Warehouse/Lakehouse, OpenSearch
10	model-gateway-service	Model routing, LLM calls, embeddings, token accounting, rate limits	Python, FastAPI, internal model adapter, Redis
11	verification-response-service	Grounding, evidence validation, quality gate, redaction, final answer	Python, FastAPI
12	audit-observability-service	Audit logs, traces, metrics, cost tracking, tool-call logs	Python workers, Kafka, OpenTelemetry, OpenSearch/Splunk
13	notification-service	Approval workflow, Jira draft review notification, email/Slack integration	Python, FastAPI, Kafka

4. MVP Architecture Flow

```
User
  -> chat-api-service
  -> context-api
  -> orchestrator-service
  -> registry-api        # resolve approved vulnerability workflow definition
  -> policy-api          # authorize workflow execution and constraints
  -> workflow-runtime-service
  -> Temporal
  -> agent-runtime-service
  -> tool-gateway-service
  -> cyber-domain-api
  -> verification-response-service
  -> chat-api-service streams final response
```

5. Policy API vs Registry API

API	Question Answered	Responsibilities
policy-api	Is this allowed now?	Workflow, agent, skill, tool, data-boundary, masking, approval, and runtime constraint decisions.
registry-api	What exists and is approved?	Workflow, agent, skill, tool, model, prompt, semantic model, and data product definitions and versions.

- Registry says graph_query_tool is an approved capability.

- Policy says this user and tenant may use graph_query_tool only with max_depth=4, read_only=true, and pii_mode=masked.

6. Temporal Usage

Temporal is recommended for the MVP workflow runtime. The workflow-runtime-service remains the API boundary, while Temporal owns durable workflow state, retries, timers, heartbeats, signals, cancellation, and execution history.

Platform Concept	Temporal Mapping
vulnerability_chaining_workflow	Temporal workflow
workflow step	Temporal activity
long-running agent execution	Activity; later child workflow if needed
approval to create Jira	Temporal signal
quality loop	Workflow loop with bounded iterations
status/progress query	Workflow query plus Redis streaming cache
timeout/retry	Temporal retry policy and timeouts

```
Temporal workflow sequence:
1. resolve_entity_activity
2. retrieve_vulnerability_findings_activity
3. enrich_cve_activity
4. map_asset_application_activity
5. run exposure_context, graph_path_query, and data_impact activities
6. risk_scoring_activity
7. remediation_recommendation_activity
8. jira_epic_draft_activity and jira_story_task_draft_activity
9. evidence_packaging_activity
10. quality_gate_activity
11. wait for approval signal if Jira creation is requested
12. create_jira_activity only after approval
```

7. Vulnerability Chain Workflow

Step	Skill / Activity	Purpose
1	entity_resolution_skill	Resolve application, asset, CVE, business unit, environment, and tenant context.
2	vulnerability_finding_retrieval_skill	Retrieve high/critical vulnerability findings scoped by tenant and app/asset.
3	cve_exploitability_enrichment_skill	Add CVSS, EPSS, KEV, exploit availability, and exploit maturity.
4	asset_application_mapping_skill	Map vulnerable assets to applications, services, owners, and environments.
5	exposure_context_skill	Identify internet-facing, partner-facing, internal, or restricted exposure.
6	graph_path_query_skill	Find paths from vulnerable assets to services, identities, and sensitive data.
7	data_impact_skill	Determine whether customer/restricted data is reachable.
8	risk_scoring_skill	Score and rank vulnerability chains.
9	remediation_recommendation_skill	Recommend chain-breaking remediation actions.
10	jira_epic_draft_skill	Generate evidence-backed Jira epic draft.
11	jira_story_draft_skill / jira_task_draft_skill	Generate story/task drafts for patching, control validation, and data path closure.
12	evidence_packaging_skill	Package evidence references and source

		metadata.
13	response_summary_skill	Build draft answer.
14	verification-response-service	Validate grounding, redact sensitive data, run quality gate, and produce final response.

8. MVP Agents, Skills, and Tools

8.1 Agent

- vulnerability_chaining_agent - one parent agent for the MVP. Full subagent infrastructure is not required initially.

8.2 Approved Skills

- entity_resolution_skill
- vulnerability_finding_retrieval_skill
- cve_exploitability_enrichment_skill
- asset_application_mapping_skill
- exposure_context_skill
- graph_path_query_skill
- data_impact_skill
- risk_scoring_skill
- evidence_packaging_skill
- remediation_recommendation_skill
- jira_epic_draft_skill
- jira_story_draft_skill
- jira_task_draft_skill
- response_summary_skill

8.3 Approved Tools

- vulnerability_findings_tool
- cve_enrichment_tool
- asset_inventory_tool
- application_ownership_tool
- network_exposure_tool
- graph_query_tool
- data_classification_tool
- runbook_retrieval_tool
- evidence_store_tool
- jira_draft_tool
- jira_create_tool

9. Jira Epic and Ticket Creation

The MVP includes Jira epic/story/task draft generation and approval-gated ticket creation. The system can recommend and draft remediation work, but it must not commit operational changes or create production Jira tickets without approval.

Action	MVP Behavior
Generate Jira epic draft	Allowed automatically after evidence and risk score are available.
Generate Jira story/task drafts	Allowed automatically, but must include evidence refs and acceptance criteria.
Create Jira epic/story/task	Requires approval signal and policy-api authorization.
Assign Jira owner or notify app owner	Requires approval and owner verification.
Auto-close or mark remediated	Blocked in MVP.
Patch server / change firewall / rotate secret	Blocked in MVP.

9.1 Jira Output Contract

```
Jira epic draft must include:
- title
- summary
- business impact
- risk level and risk score
- affected applications
- affected assets
- recommended remediation plan
- acceptance criteria
- evidence references
- confidence and limitations

Jira story/task drafts must include:
- title
- priority
- owner team or unresolved owner marker
- affected assets/apps
- action required
- acceptance criteria
- evidence references
```

10. Policy Rules for Jira and Workflow Execution

```
policy_id: mvp_vulnerability_chain_policy_v1

workflow_execution:
  allow:
    - execute_vulnerability_chaining_workflow
  require:
    - tenant_id
    - user_context
    - evidence_required
    - final_verification_required
  constraints:
    read_only: true
    pii_mode: masked
    max_graph_depth: 4
    max_tool_calls: 100

jira_policy:
  allow:
    - generate_jira_epic_draft
    - generate_jira_story_drafts
    - generate_jira_task_drafts
  approval_required_for:
    - create_jira_epic
    - create_jira_story
    - create_jira_task
    - assign_jira_owner
    - notify_application_owner
```

```
deny:
  - auto_close_jira
  - auto_mark_remediated
  - patch_server
  - change_firewall_rule
  - rotate_secret
  - disable_account
require_for_create:
  - evidence_refs
  - risk_score
  - affected_assets
  - remediation_reason
  - owner_verification
```

11. MVP API Inventory

API	Owner	Purpose
POST /v1/chat/messages/stream	chat-api-service	Submit user request and stream progress/final answer.
GET /v1/workflows/{id}/status	chat-api-service	Return workflow execution status.
POST /v1/context/resolve	context-api	Resolve user, tenant, session, conversation, and memory context.
GET /v1/conversations?days=30	context-api	Retrieve recent conversations for the user/tenant.
POST /v1/orchestrate	orchestrator-service	Classify intent and route to approved workflow.
GET /v1/workflows/{workflow_id}	registry-api	Get workflow definition and version.
GET /v1/agents/{agent_id}	registry-api	Get agent definition.
GET /v1/skills/{skill_id}	registry-api	Get skill definition.
GET /v1/tools/{tool_id}	registry-api	Get tool definition.
POST /v1/policy/evaluate	policy-api	Authorize workflow/agent/skill/tool/Jira creation.
POST /v1/workflows/run	workflow-runtime-service	Start Temporal workflow.
POST /v1/executions/{id}/signal	workflow-runtime-service	Send approval/cancel/update signal.
POST /v1/agents/execute	agent-runtime-service	Execute vulnerability_chaining_agent.
POST /v1/tools/invoke	tool-gateway-service	Invoke approved tool with policy enforcement.
POST /v1/jira/drafts	tool-gateway-service or notification-service	Create Jira draft artifact.
POST /v1/approvals	notification-service	Request human approval.
POST /v1/jira/issues	tool-gateway-service	Create Jira only after approval.
POST /v1/verify	verification-response-service	Verify response and quality.
POST /v1/audit/events	audit-observability-service	Record audit event.

12. MVP Data Stores

Store	Purpose
Postgres	Tenants, sessions, conversations, registry metadata, policy metadata, workflow metadata, memory facts, Jira draft metadata.
Redis	Active session cache, workflow progress, SSE fanout, rate limits, model token budgets, idempotency keys.
Temporal	Durable workflow execution, timers, retries, signals, cancellations, execution history.
Kafka	Audit events, tool-call events, indexing events, memory/evidence events, analytics stream.
Graph DB	Asset/application/service/identity/data relationship graph and attack paths.

OpenSearch	Search across runbooks, evidence metadata, audit search, operational logs.
Vector DB / pgvector	RAG over runbooks, policies, and evidence summaries.
Warehouse/Lakehouse	Governed cyber data products.
Object Store	Evidence bundles, generated reports, Jira draft attachments.

13. Verification and Quality Loop

```
Draft response
  -> verification-response-service
  -> quality gate
       checks: evidence, chain path, data impact, risk explanation, Jira draft completeness, redaction
  -> if passed: final response or approval request
  -> if failed:
       workflow-runtime-service executes bounded improvement loop
       retries missing evidence skill or rebuilds response
       max_iterations = 2
```

- Verification proposes improvement actions; workflow-runtime-service executes them through the governed path.
- verification-response-service must not directly call enterprise tools or databases.

14. MVP Deployment Baseline

Layer	Recommended Stack
API runtime	Python + FastAPI
Workflow runtime	Temporal + Python SDK
Workers	Python async workers and Temporal workers
Container platform	Kubernetes / OpenShift
CI/CD and GitOps	GitHub Actions/Jenkins + ArgoCD
Infrastructure as Code	Terraform
Secrets	Vault / cloud KMS
Observability	OpenTelemetry, Prometheus, Grafana, Splunk/OpenSearch

15. MVP Build Phases

Phase	Deliverable
Phase 1	Core service skeletons: chat-api, context-api, orchestrator, policy-api, registry-api, workflow-runtime, agent-runtime.
Phase 2	Temporal vulnerability_chaining_workflow with stubbed tools and synthetic cyber data.
Phase 3	Tool-gateway integration with graph query, vulnerability findings, asset inventory, data classification, and evidence store.
Phase 4	Verification quality gate, evidence-backed response, and streaming progress.
Phase 5	Jira epic/story/task draft generation and approval-gated Jira creation.
Phase 6	Audit hardening, tenant boundary testing, load testing, and production readiness.

16. Final MVP Design Principle

```
Keep MVP focused:
  one workflow,
  one parent agent,
  approved skills,
  governed tools,
  Temporal for durable execution,
  policy-api for runtime authorization,
  registry-api for approved definitions,
  Jira draft generation with approval-gated creation,
  verification-response-service for final answer quality.
```